SECURING THE PERIMETER



AYUSH KUMAR JHA

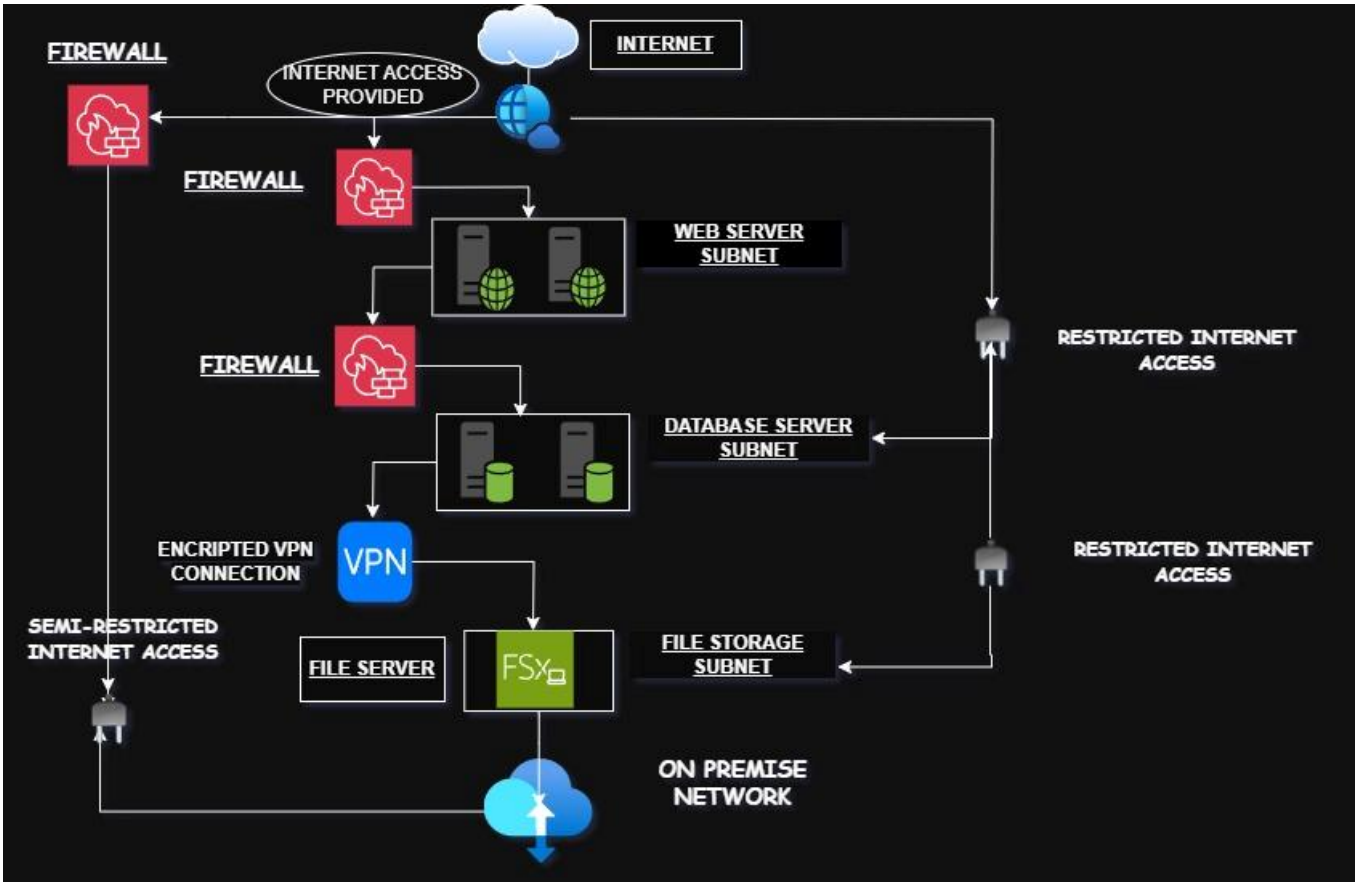
16-01-2025

Identify Network Vulnerabilities

1. All servers have a direct internet connection
Direct internet access for all servers exposes them to potential cyberattacks, such as unauthorized access, malware, or Distributed Denial of Service (DDoS) attacks. Without proper firewalls or network segmentation, attackers could exploit vulnerabilities in any of the servers and gain access to sensitive data or disrupt services.
2. Single subnet for all servers
Placing all five servers in a single subnet means no network segmentation. If one server is compromised, it becomes easier for attackers to move laterally and access the others A breach in one web server could allow attackers to access the database or even the file storage server, increasing the potential damage.
3. Unrestricted access to the file storage server
The file storage server is only meant to be accessible from the on-premise network. However, without access restrictions or firewall rules, it remains exposed to the virtual network and potentially the internet. Unauthorized users could access or steal sensitive files stored on this server if proper access control measures are not implemented.

Network Redesign

Place the updated network diagram here.



Convince the Stakeholders

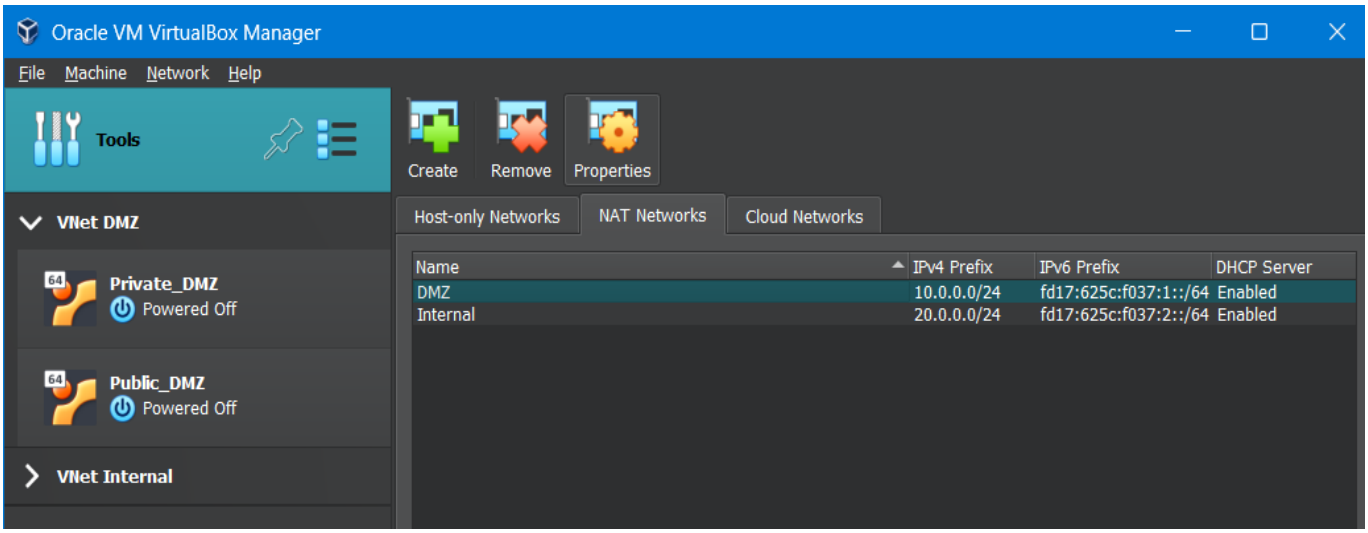
Why do we need to add firewalls to our network?
Firewalls are critical for controlling and filtering traffic entering and leaving different parts of the network They provide different key security features such as: 1. Traffic Control 2. Threat Prevention 3. Isolation and containment
What is the benefit of having different areas in our network for web servers and database servers?
Segregating web servers (public-facing) and database servers (internal-facing) is a fundamental security practice known as network segmentation. A few of the advantages are: 1. Restricted Access 2. Damage Containment 3. Minimized Exposure
What does a VPN do for our connection to the file storage server?
A VPN is essential for securing the connection between your on-premise network and the file storage server. A few of its benefits are: 1. Encryption 2. Authentication 3. Secure Remote Access

Section 2:

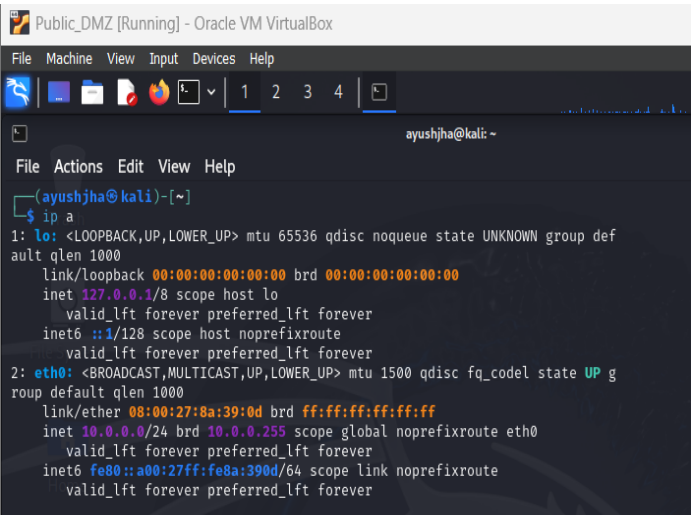
Building a secure Network Architecture in VirtualBox

Network Setup

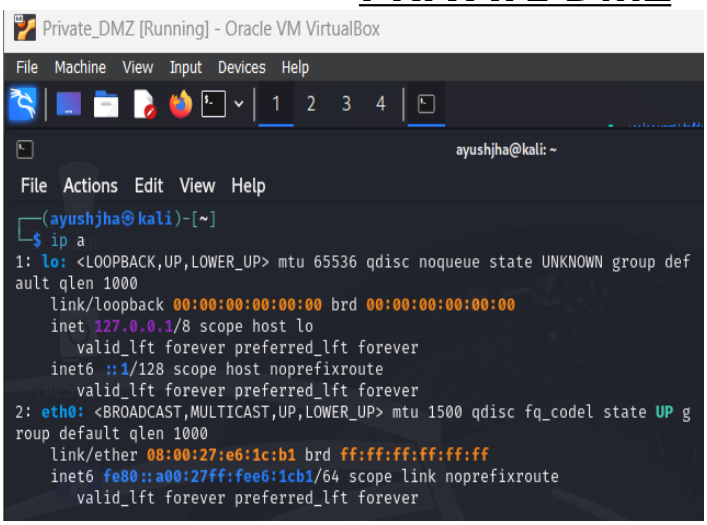
Screenshot of the DMZ Virtual Network with the two subnets



PUBLIC DMZ

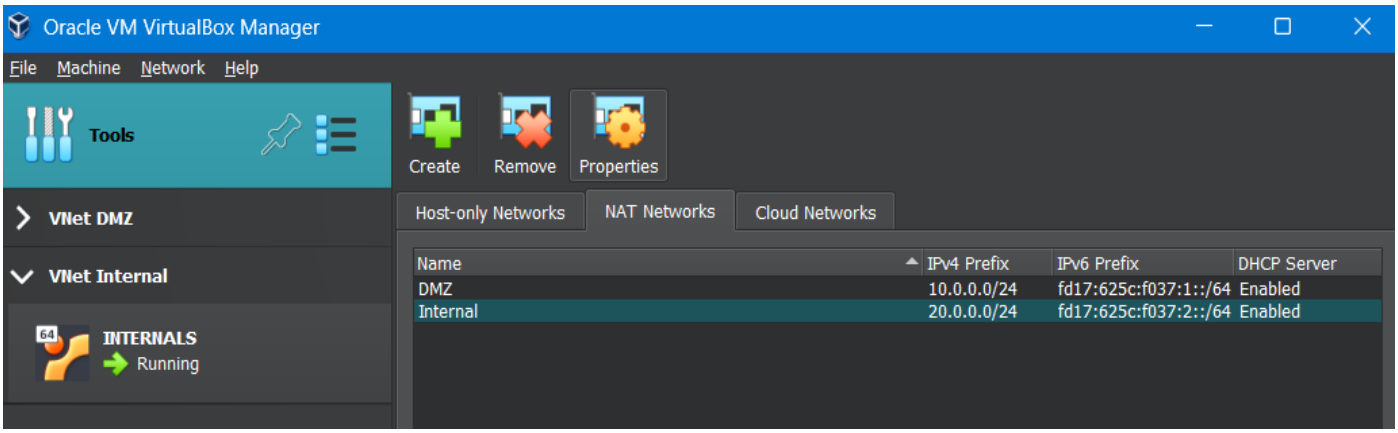


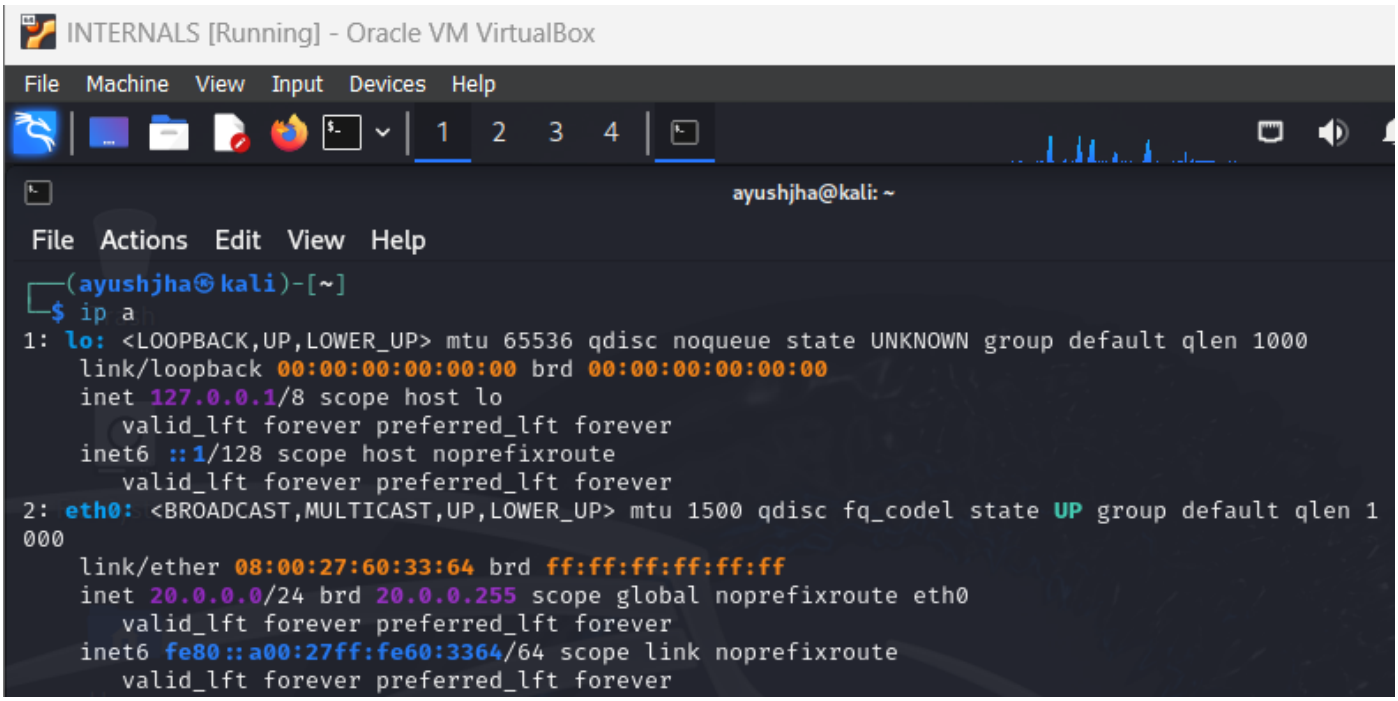
PRIVATE DMZ



Network Setup

Screenshot of the Internal Virtual Network with the subnet





Section 3:
Continuous Monitoring with a SIEM

Understanding SIEM Benefits

1. Centralized Monitoring and Logging

A SIEM system aggregates logs and security data from multiple sources, such as servers, firewalls, and endpoints, into a centralized platform. This provides a unified view of all network activities, making it easier to identify unusual patterns and potential threats. By consolidating data, SIEM reduces the time and effort needed to investigate incidents, improving efficiency in managing security events.

2. Real-Time Threat Detection and Alerts

SIEM systems use advanced analytics, including machine learning and correlation rules, to detect suspicious activities in real-time. They automatically generate alerts for security teams to act upon. Early detection of threats reduces response time, minimizing the risks of data breaches and mitigating the potential damage to critical assets.

3. Regulatory Compliance Support

SIEM systems often include built-in compliance reporting capabilities, allowing organizations to demonstrate adherence to regulations such as GDPR, HIPAA, or PCI DSS by maintaining and analyzing security logs. Simplifies compliance audits and reduces the risk of non-compliance penalties by ensuring that required security measures and logging standards are met

Section 4:
Zero Trust

Zero Trust Comparison

1. Pre-Session Access

Zero Trust Approach: Access to resources is granted only for the duration of a specific session and is tightly scoped to the minimum permissions required for that session. Access decisions are based on the specific request, including who is requesting, what resource is needed, and why.	**Traditional Approach:** Access is often granted based on user roles or credentials during login and remains valid until manually revoked. Once inside the network, users or devices often have excessive access to resources.

Benefits of Zero Trust: Benefits are as follows:

1. Limits the potential damage from compromised accounts or devices.
2. Attackers cannot easily move within the network to exploit other systems.

2. Secured Communication

Zero Trust Approach: Encrypts all communications, both inside and outside the corporate network, ensuring no implicit trust is given to internal traffic. Leverages advanced encryption protocols like TLS for all data transfers.	**Traditional Approach:** Data is often encrypted only when transferred outside the corporate network (e.g., through VPNs), with less emphasis on securing internal communications. Internal communications within the network are often considered "trusted" and may lack encryption.

Benefits of Zero Trust: Benefits are as follows:

1. Ensures that even compromised internal systems or users cannot intercept sensitive data.
2. Safeguards communications in hybrid and multi-cloud environments.

Zero Trust Comparison

3. Continuous Monitoring	
Zero Trust Approach: Continuously monitors the integrity and behavior of users, devices, and assets. Leverages AI and ML to detect anomalies and adapt access policies dynamically.	**Traditional Approach:** Relies on periodic audits or scheduled security checks. Security monitoring focuses on detecting and responding to specific incidents or breaches.
Benefits of Zero Trust: Benefits are as follows: 1. Identifies potential breaches before they escalate. 2. Provides detailed insights into real-time activity, enabling faster and more effective incident response	

Zero Trust Model

Recommended Zero-Trust Model is ENCLAVE GATEWAY

The Enclave Gateway model is the best fit for XYZ due to its ability to secure communication, control access, and segment the network effectively. Given XYZ's recent security breach and the identified vulnerabilities in their perimeter network security, this model provides the necessary capabilities to address their challenges and align with their security objectives.

How the Enclave Gateway Model Addresses XYZ's Specific Security Challenges:

CHALLENGE 1:

Problem:- *All servers are in a single virtual network and subnet, with public-facing servers directly exposed to the internet*

Solution:- *The Enclave Gateway model isolated resources into smaller, secure " enclaves", creating logical segmentation of web servers, database servers, and file storage servers.*

CHALLENGE 2:

Problem:- *The absence of proper access control allows overprivileged communication between servers.*

Solution:- *The gateway enforces strict access policies, allowing only necessary, scoped communication between resources*

CHALLENGE 3:

Problem:- *XYZ lacked visibility into network activity, which contributed to the delayed detection of the breach.*

Solution:- *The Enclave Gateway is integrated with monitoring tools like SIEM systems to provide real-time insights into enclave traffic, enhancing visibility and incident detection.*

Continued…..

Alignment with XYZ's Security Objectives and Network Situation

1. Strengthen Perimeter Security

The gateway is a strong intermediary for all inbound and outbound traffic, filtering and inspecting it based on defined policies. This prevents unauthorized access to internal resources.

Objective 2: Reduce Attack Surface

The attack surface is minimized by isolating resources into enclaves. Even if one enclave is compromised, lateral movement is restricted, limiting the impact of an attack.

3. Simplify Access Management

The Enclave Gateway centralizes access control, providing a single point to define and enforce policies. It eliminates the complexity of managing access controls across multiple systems.

4. Support for Hybrid Infrastructure

XYZ's on-premise network connects to a virtual network via the Internet. The Enclave Gateway is well-suited for hybrid environments, allowing secure connections between on-premise and cloud resources.